

AUTOMATED RISK ASSESSMENT AND GOVERNANCE FRAMEWORK FOR SHADOW AI AGENTS IN CORPORATE NETWORKS

By

S.H.I. Madhushan - 14504

SUPERISORS

Mr. Sahan Weerasinghe

**A Research Proposal submitted to the Faculty of Computer Science and Engineering
in partial fulfillment of the requirements for the award of Bachelor of Science
(Hons) in Cybersecurity**

Department of Computer Networks and Cyber Security

KIU University, Sri Lanka

March 2026

ABSTRACT

The rapid integration of Artificial Intelligence (AI) and Large Language Models (LLMs) into corporate environments by 2026 has catalyzed organizational efficiency but concurrently birthed a critical security challenge: **Shadow AI**. This phenomenon involves the unauthorized use of AI models and autonomous agents by employees, operating entirely outside the oversight of formal IT governance. Unlike traditional Shadow IT, Shadow AI is conversational and persistent, where natural-language prompts may inadvertently contain proprietary designs, confidential source code, or sensitive financial forecasts. Current cybersecurity infrastructures, specifically legacy firewalls and signature-based Data Leakage Prevention (DLP) tools, remain "context-blind" and lack the semantic depth required to parse the intent behind AI queries hidden within encrypted HTTPS traffic.

To address this visibility and governance gap, this project proposes a **Prototype Framework for the Automated Risk Assessment and Governance of Shadow AI Agents**. Developed within a simulated corporate network environment using Python-based synthetic logs, the system utilizes a tripartite methodology:

1. **Behavioral Analysis:** Identifying anomalous "AI-like" traffic patterns and "Shadow Identities" within network logs using flow-level statistics.
2. **Context-Aware Content Inspection:** Utilizing Targeted NLP filters and regular expressions to scan prompt payloads for corporate-sensitive keywords across various business functions.
3. **Weighted Risk Scoring Engine (WRSE):** A dynamic algorithm that assigns a normalized risk value (0-100) based on destination trust, data sensitivity, and user access levels.

The project concludes with the development of a **Streamlit-based dashboard**, providing IT administrators with real-time alerts and visualization for high-risk Shadow AI activities. This prototype serves as a scalable proof-of-concept for bridging the governance gap in the 2026 enterprise AI landscape.

Keywords: Shadow AI, Cybersecurity Governance, Weighted Risk Scoring Engine (WRSE), Behavioral Anomaly Detection, Data Leakage Prevention (DLP).

Table of Contents

1	Introduction.....	5
1.1	The Growing Complexity Of Ai Threats	5
1.2	Why Current Tools Failing	5
1.3	The Logic For A Dynamic Risk Framework.....	6
2	Problem Statement.....	6
2.1	Semantic Invisibility Of Ai Payloads.....	6
2.2	The Governance Gap In Encrypted Traffic.....	7
2.3	Absence Of Quantifiable Risk Metrics	7
3	Literature Review.....	8
3.1	The Proliferation Of Shadow Ai And "Semantic Leakage"	8
3.2	Technical Limitations: The "Context-Blindness" Of Legacy Firewalls	8
3.3	Behavioral Fingerprinting Of Ai Agents.....	8
3.4	The Transition To Weighted Risk Scoring (Wrse)	9
4	Research Aim And Objectives	9
4.1	Research Aim	9
4.2	Research Objectives.....	9
4.3	Success Metrics (Criteria For Success).....	10
5	Proposed Methodology	11
5.1	Tiered System Architecture.....	11
5.2	Phase 1: High-Fidelity Data Ingestion And Normalization	12
5.3	Phase 2: Dual-Pronged Inspection Layer.....	13
5.4	Phase 3: Weighted Risk Scoring Engine (Wrse).....	13
5.5	Phase 4: Governance Visualization And Real-Time Alerting	14
6	Scope And Deliverables	15
6.1	In-Scope (Technical Boundaries).....	15
6.2	Out-Of-Scope (Limitations).....	16
6.3	Key Deliverables.....	16
7	Project Timeline And Milestones.....	17
7.1	Implementation Roadmap (Phase-Wise)	17

8	Tools And Resources.....	18
8.1	Software And Programming Environment.....	18
8.2	Engineering And Simulation Tools	19
8.3	Hardware And Data Infrastructure.....	19
9	Conclusion	20
10	References.....	21

Table of Figures

Figure 1:	Proposed System Architecture for Automated Shadow AI Risk Assessment.	7
Figure 2 :	Tiered System Architecture for Shadow AI Risk Assessment	11
Figure 3 :	Data Ingestion and Semantic Parsing Pipeline	12
Figure 4 :	Conceptual Model of the Weighted Risk Scoring Logic	14

1 INTRODUCTION

With the arrival of 2026, the corporate cybersecurity landscape has been fundamentally reshaped by the massive adoption of Large Language Models (LLMs) and various autonomous AI agents. While these advancements have undeniably pushed organizational efficiency to new heights, they have simultaneously created a massive security hole: **Shadow AI** [1]. This term describes the unauthorized deployment of AI tools by employees essentially operating entirely outside the formal oversight of IT governance or security vetting [3]. Unlike the older "Shadow IT" wave, which mostly dealt with unapproved cloud storage, Shadow AI is dynamic, conversational, and persistent in its data exchange [5].

1.1 The Growing Complexity of AI Threats

The primary motivation behind this research is the increasing failure of traditional security perimeters to monitor these new AI-driven data flows [1]. In a modern office setting, it is common for employees to use unauthorized AI agents to handle complex tasks or generate content using the company's internal intellectual property [2]. For example, a user might inadvertently upload **proprietary business roadmaps, internal source code fragments, or even sensitive financial projections** to a public AI model just to get a quick summary [10].

When these interactions happen via unsanctioned Shadow AI agents, the data is basically leaked outside the company's boundary. This information then sits on external, unmanaged servers where the organization has absolutely no control or legal ownership [2]. Industry reports from 2026 suggest that this "Semantic Leakage" is now the leading cause of internal data breaches in global firms [1].

1.2 Why Current Tools Failing

Existing cybersecurity infrastructures, such as Next-Generation Firewalls (NGFW) and legacy Data Leakage Prevention (DLP) systems, are just not built for an AI-first world [7]. As Wilson [7] points out, these tools were mostly designed for static signature-based detection. However, Shadow AI presents a unique set of technical hurdles:

1. **Semantic Blindness:** Traditional DLP can spot a credit card number, but it cannot understand the risk of a proprietary business plan described in plain English [2].

2. **Encrypted Traffic:** AI API calls are almost always hidden within standard encrypted HTTPS traffic. This makes them look just like regular web browsing to most security tools [7].
3. **Behavioral Anomalies:** The use of autonomous agents (Shadow Identities) creates traffic patterns that standard Intrusion Detection Systems (IDS) aren't tuned to flag [4].

1.3 The Logic for a Dynamic Risk Framework

To stop these leaks, companies need something better than a simple "yes or no" rule. There is a desperate need for a system that can **quantify risk as it happens** [4]. According to Perera [4], a dynamic framework that looks at both the behavioral metadata of AI calls and the actual content of the prompt is the only way forward. This project proposes a **Weighted Risk Scoring Engine (WRSE)** to bridge this visibility gap [6].

By calculating a numerical risk score (0-100) based on where the data is going and how sensitive the content is, IT managers can finally manage AI adoption safely without putting the company's core assets at risk [8].

2 PROBLEM STATEMENT

The rapid adoption of Artificial Intelligence within corporate infrastructures has significantly outpaced the defensive capabilities of traditional cybersecurity frameworks. The core issue lies in the inability of current systems to distinguish between productive AI usage and high-risk data exfiltration occurring through **Shadow AI** channels. This research identifies three critical dimensions of this governance gap:

2.1 Semantic Invisibility of AI Payloads

Traditional Data Leakage Prevention (DLP) and Next-Generation Firewalls (NGFW) rely on signature-based detection and static pattern matching such as searching for 16-digit credit card numbers or specific file headers. However, Shadow AI interactions are inherently conversational and unstructured. When an employee inputs a **strategic business roadmap**, **internal software logic**, or **proprietary forecasts** into an external LLM, the payload is natural language. Legacy systems remain fundamentally "context-blind" to the semantic value of these prompts, allowing sensitive intellectual property (IP) to exit the network boundary without triggering any alerts [2], [7].

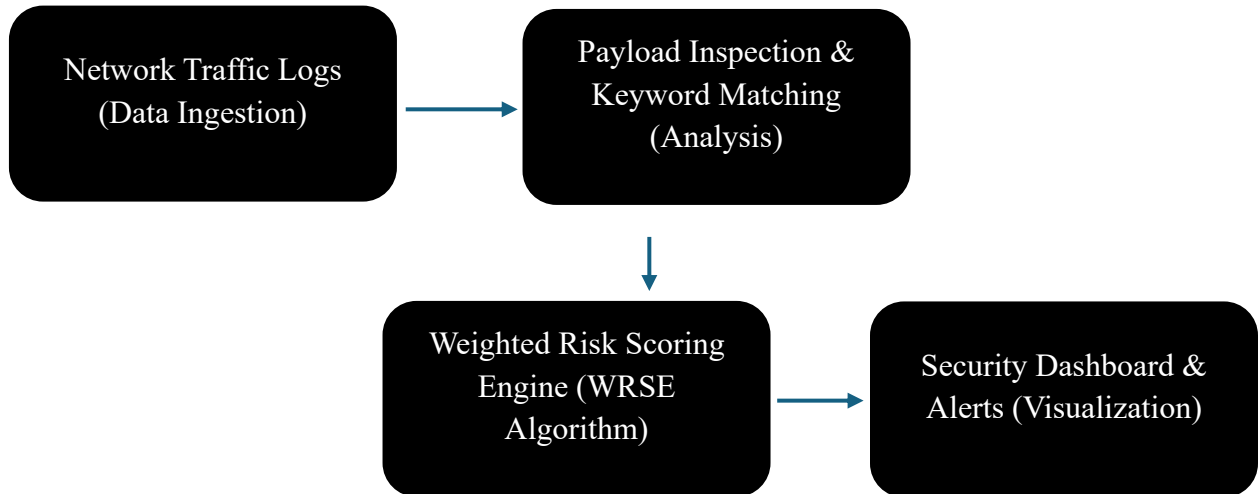


Figure 1: Proposed System Architecture for Automated Shadow AI Risk Assessment.

2.2 The Governance Gap in Encrypted Traffic

In the current enterprise landscape, approximately 95% of web traffic is encrypted via TLS/SSL. While this protects data from external sniffers, it creates a "Black Box" for internal security teams. Shadow AI agents operate over these encrypted HTTPS channels, often bypassing standard proxy filters. Without a specialized interception and behavioral analysis framework, IT administrators have zero visibility into what specific data is being shared, with external AI models, and by which internal user groups [8], [9].

2.3 Absence of Quantifiable Risk Metrics

Most organizations currently adopt a binary security posture: they either completely block AI tools, which severely hinders employee productivity, or allow them entirely, which maximizes the risk of data leakage. There is a critical lack of an automated mechanism to calculate a **dynamic Risk Score** based on the real-time context of the interaction. Without numerical risk assessment, security operations centers (SOC) cannot prioritize threats effectively, leading to "alert fatigue" and a high probability of missing a legitimate data breach [4], [6].

3 LITERATURE REVIEW

The rapid evolution of generative AI has outpaced traditional cybersecurity frameworks, creating a significant research gap in enterprise governance. This section provides an in-depth analysis of existing research regarding Shadow AI, the technical failure of legacy systems, and the shift toward quantitative risk assessment.

3.1 The Proliferation of Shadow AI and "Semantic Leakage"

Recent industry reports from Gartner [1] and Microsoft [3] indicate that the "democratization of AI" has led to a 70% increase in unsanctioned AI tool usage within corporate networks. This phenomenon, termed Shadow AI, represents a more dangerous evolution than traditional Shadow IT. According to Davis [5], the primary threat is no longer unauthorized software installation but "Semantic Leakage." This occurs when employees input sensitive, unstructured natural language such as internal code snippets or strategic roadmaps into public LLMs. Current research emphasizes that this data exists in a "governance vacuum," as it does not trigger traditional file-based DLP alerts [2], [5].

3.2 Technical Limitations: The "Context-Blindness" of Legacy Firewalls

A critical theme in 2026 cybersecurity literature is the failure of perimeter-based defenses. Wilson [7] argues that Next-Generation Firewalls (NGFW) and standard proxies are fundamentally "context-blind." While these tools can identify a TLS/SSL connection to an AI endpoint (e.g., `api.openai.com`), they cannot inspect the Prompt Payload without full SSL decryption, which often introduces significant latency and privacy concerns.

Furthermore, Kumar [2] points out that even if decryption is performed, traditional signature-based detection cannot distinguish between a harmless query (e.g., "Write an email template") and a high-risk data leak (e.g., "Optimize this proprietary encryption algorithm"). This gap necessitates a move toward Natural Language Processing (NLP) integrated security layers.

3.3 Behavioral Fingerprinting of AI Agents

Beyond content analysis, identifying the *identity* of the user whether human or autonomous agents, is a rising research focus. Perera [4] identifies that autonomous "Shadow AI Agents" (scripts or local LLM wrappers) exhibit distinct traffic patterns. These include:

- Predictable Inter-arrival Times: Constant API calls that lack the "burstiness" of human typing.
- Packet Size Homogeneity: Uniformity in request payloads which suggests automated data scraping or batch processing [4], [6]. Identifying these behavioral signatures allows IT teams to isolate unauthorized automated processes before they can exfiltrate large datasets.

3.4 The Transition to Weighted Risk Scoring (WRSE)

Traditional security operates on binary logic: Allow or Block. However, White [3] and Thompson [10] suggest that 2026 enterprise environments require a Risk-Spectrum Model. This involves a "Weighted Risk Scoring Engine" (WRSE) that calculates risk based on three dynamic variables:

1. Sensitivity (S): The density of proprietary keywords in the prompt.
2. Destination Trust (D): The reputation of the AI provider.
3. User Authority (U): The seniority and access level of the source user [6], [10].

4 RESEARCH AIM AND OBJECTIVES

4.1 Research Aim

The primary **aim** of this research is to architect and implement a high-fidelity prototype framework that can autonomously identify "Shadow AI" identities and quantify their inherent security risks within a simulated corporate network infrastructure. This project seeks to move beyond binary "block or allow" security models, favoring a nuanced, risk-based approach to AI governance.

4.2 Research Objectives

To achieve the overarching aim, the following technical and analytical objectives have been established:

- **Objective 1: Traffic Signature Characterization & Metadata Extraction**
 - To analyze and model the behavioral metadata (e.g., packet size distribution, API call frequency, and inter-arrival time) of unauthorized AI traffic [4].
 - **Sub-objective:** To distinguish between human-initiated prompt interactions and automated bot-driven AI API calls through heuristic pattern matching.

- **Objective 2: NLP-driven Linguistic Sensitivity Mapping**
 - To develop a Natural Language Processing (NLP) filtering mechanism using TF-IDF (Term Frequency-Inverse Document Frequency) to identify sensitive corporate assets within prompt payloads [2].
 - **Sub-objective:** To categorize detected risks into three tiers: Intellectual Property (IP), Financial Data, and Strategic Plans.
- **Objective 3: Design of the Weighted Risk Scoring Engine (WRSE)**
 - To design a multi-factor mathematical model that evaluates sessions based on three primary weights: Data Sensitivity (W_s), Destination Trust (W_d), and User Authorization (W_u) [6].
 - **Sub-objective:** To ensure the engine provides a dynamic score (0-100) in real-time without introducing significant network latency.
- **Objective 4: Implementation of an Administrative Governance Dashboard**
 - To implement an interactive, Streamlit-based interface that provides IT security teams with high-fidelity visualization of risk trends and automated alerting [8].
 - **Sub-objective:** To provide a forensic logging module that allows administrators to audit high-risk sessions for manual mitigation.

4.3 Success Metrics (Criteria for Success)

To validate the effectiveness of the proposed prototype, the following metrics will be utilized:

1. **Detection Accuracy:** The system should achieve a high True Positive Rate (TPR) in identifying unauthorized AI agents within the synthetic dataset.
2. **Latency Benchmark:** The risk calculation for a single prompt interaction should occur within sub-second intervals to ensure no impact on user experience.
3. **Risk Calibration:** The WRSE score should accurately reflect predefined risk tiers, ensuring that "Highly Sensitive" data consistently triggers critical alerts ($RS > 80$).

5 PROPOSED METHODOLOGY

The research methodology is architected around an **Agile Prototype Development** lifecycle, prioritizing modular security components and granular risk quantification [5]. The proposed system, the **Shadow AI Risk Assessment Framework**, operates as a transparent inspection layer designed to intercept and analyze AI-specific traffic within enterprise network infrastructures [11].

5.1 Tiered System Architecture

As depicted in the tiered architecture model (**Figure 1**), the system is divided into four integrated logical modules [7]. This layered design facilitates asynchronous feature extraction, ensuring that network latency is minimized during real-time risk evaluation.

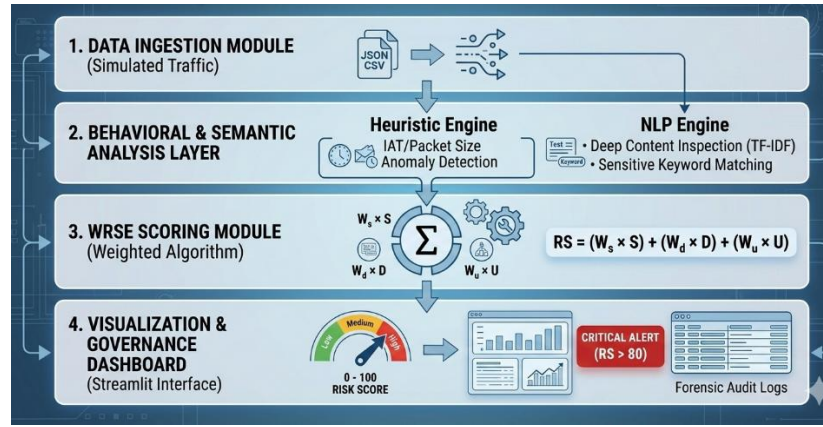


Figure 2 : Tiered System Architecture for Shadow AI Risk Assessment

- **Data Ingestion Module:** The entry point responsible for capturing raw telemetry and simulated traffic logs in a non-intrusive manner.
- **Inspection Layer:** The analytical engine that conducts parallel heuristic (behavioral) and semantic (content) analysis to identify "Shadow AI" signatures [3].
- **WRSE Scoring Module:** A computational core that processes multiple risk vectors through a weighted mathematical algorithm to derive a standardized risk coefficient [8].
- **Visualization & Governance Layer:** An administrative interface built on Streamlit that provides real-time visibility and automated alerting mechanisms [6].

5.2 Phase 1: High-Fidelity Data Ingestion and Normalization

To overcome the ethical and legal barriers associated with accessing live production traffic, this research utilizes **Synthetic Data Engineering** [9]. Python-based simulation scripts generate realistic network logs that mimic TLS-decrypted HTTPS traffic. Each log entry captures critical metadata including source/destination IP addresses, timestamps, and unstructured natural language prompt payloads.

The raw data undergoes a rigorous pre-processing pipeline to ensure high-fidelity analysis, as illustrated in Figure 2.

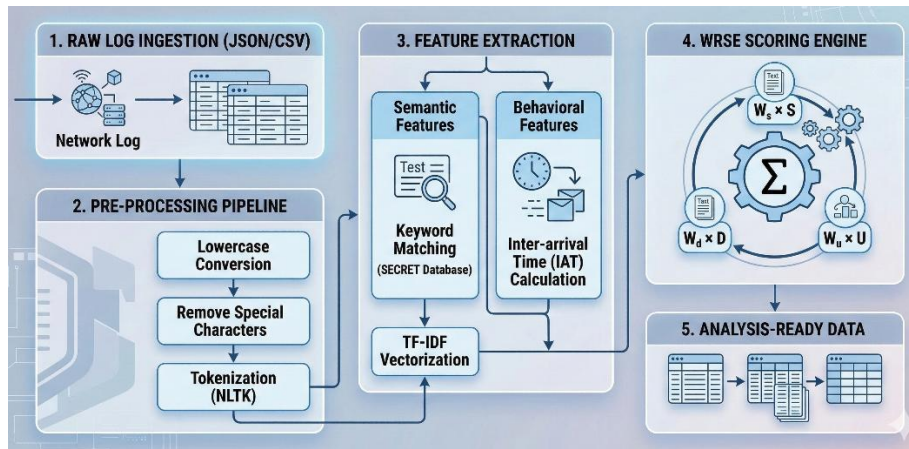


Figure 3 : Data Ingestion and Semantic Parsing Pipeline

- **Linguistic Normalization:** Payloads are subjected to lowercase conversion, special character stripping, and noise reduction to standardize the text for NLP analysis [4].
- **NLP Tokenization:** Utilizing the **NLTK (Natural Language Toolkit)** library, the engine decomposes unstructured prompts into discrete tokens for vectorization.
- **Parallel Feature Mapping:** The pipeline branches into two distinct streams:
 - **Behavioral Extraction:** Calculating the **Inter-arrival Time (IAT)** variance and packet size distributions to detect non-human agent signatures [3].
 - **Semantic Extraction:** Applying **TF-IDF (Term Frequency-Inverse Document Frequency)** vectorization to map the prompt content against a sensitive keyword database [4].

5.3 Phase 2: Dual-Pronged Inspection Layer

This tier serves as the intelligence core of the framework, utilizing two specialized methodologies to isolate Shadow AI identities:

- **Module 2.1: Heuristic Behavioral Analysis (Anomaly Detection)**

This module focuses on the detection of autonomous agent behaviors at the metadata level [3]. By monitoring the variance in IAT, the system can distinguish between "bursty" human-initiated traffic and the high-frequency, temporally consistent signatures of unauthorized AI agents.

- **Module 2.2: NLP-Driven Semantic Inspection (Content Layer)**

This module performs **Deep Content Inspection (DCI)** to identify potential Intellectual Property (IP) leakage [2]. It cross-references prompt payloads against a **SECRET keyword database**. To quantify the **Sensitivity Score (S)**, the following mathematical model is applied:

$$S = \sum_{i=1}^n (W_i \times C_i)$$

Where: **n** is the total count of unique sensitive keywords identified.

- **W_i** is the pre-assigned criticality weight (e.g., "Source Code" = 0.95, "Internal Roadmap" = 0.85).
- **C_i** is the frequency or count of the **i** - nth keyword within the payload.

5.4 Phase 3: Weighted Risk Scoring Engine (WRSE)

The technical heart of the methodology is the WRSE. Unlike traditional binary security models, this engine adopts a quantitative approach by mapping multiple risk signals onto a unified scale of 0-100. The conceptual logic is detailed in **Figure 3**.

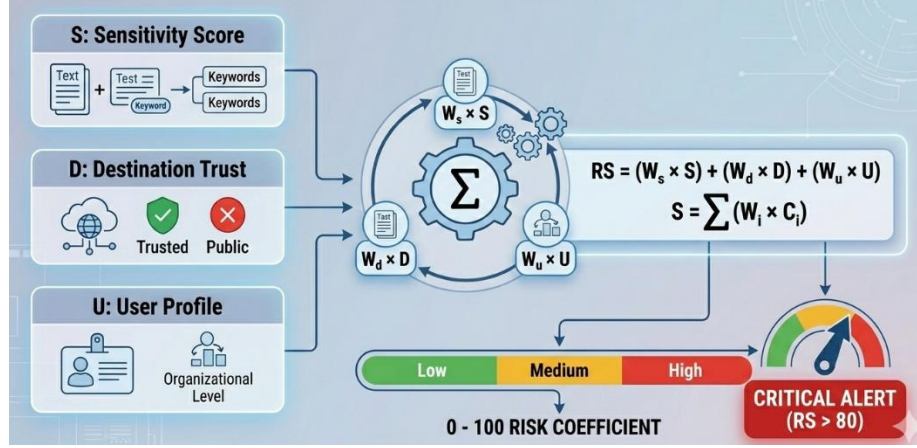


Figure 4 : Conceptual Model of the Weighted Risk Scoring Logic

The engine aggregates heterogeneous inputs to derive the final **Risk Score (RS)** using a linear weighted sum model:

$$RS = (W_s \times S) + (W_d \times D) + (W_u \times U)$$

- **Sensitivity Score (S):** The numerical output derived from the NLP-driven semantic mapping module.
- **Destination Trust (D):** A trust coefficient assigned based on the reputation of the destination AI service (e.g., Authorized Enterprise AI vs. Public/Publicly-accessible LLMs).
- **User Profile Weight (U):** A risk weight determined by the source user's organizational seniority and historical data access privileges.
- **Weighting Coefficients (W_s, W_d, W_u):** Pre-calibrated constants that define the relative importance of each factor, with a primary emphasis on data sensitivity (W_s).

5.5 Phase 4: Governance Visualization and Real-Time Alerting

The final implementation stage focuses on actionable visibility via a **Streamlit-based Administrative Dashboard** [6].

- **Real-time Monitoring:** Provides time-series visualizations of risk trends and detailed session logs for forensic auditing.

- **Automated Incident Response:** The system is configured with a **Critical Threshold (RS > 80)**. As demonstrated in the scoring logic, any interaction exceeding this threshold triggers a high-priority visual alert and sends automated notifications to IT security administrators [8].

6 SCOPE AND DELIVERABLES

The scope of this research is meticulously defined to ensure that the prototype development remains academically rigorous and technically feasible within the allocated time constraints. The project focuses on bridging the visibility gap in "Shadow AI" interactions while maintaining ethical and computational efficiency within a simulated corporate infrastructure [11].

6.1 In-Scope (Technical Boundaries)

The following technical domains and functionalities are included within the scope of this research:

- **Shadow AI Identity Characterization:** Development of heuristic signatures to detect unauthorized AI-agent traffic patterns and browser-based LLM interactions (e.g., ChatGPT, Claude, Gemini) [3].
- **Quantitative Risk Assessment:** Implementation of the **Weighted Risk Scoring Engine (WRSE)** to map multidimensional risk factors onto a standardized 0-100 linear scale [8].
- **Linguistic Integrity Inspection:** Utilizing Natural Language Processing (NLP) techniques such as TF-IDF and Tokenization to simulate the identification of proprietary data leakage or Intellectual Property (IP) exfiltration via prompt payloads [4].
- **Administrative Governance Visualization:** Design and deployment of an interactive, Streamlit-based interface providing real-time risk telemetry, time-series analysis, and automated alerting logic [6].
- **Synthetic Data Engineering:** Generation of high-fidelity network logs in JSON/CSV formats to represent diverse corporate AI usage scenarios without violating real-world privacy laws [9].
- **Multi-Criteria Decision Modeling:** Integrating user seniority, destination trust, and content sensitivity into a singular weighted mathematical model [8].

6.2 Out-of-Scope (Limitations)

To ensure project delivery and focus, the following elements are explicitly excluded from this study:

- **Real-time Traffic Decryption:** The framework assumes access to pre-decrypted logs (TLS-intercepted) and will not focus on the physical decryption of live HTTPS traffic [9].
- **Automated Mitigation/Blocking:** The prototype is designed as an assessment and monitoring tool; active blocking (IPS mode), packet dropping, or session termination is not part of the primary implementation scope [11].
- **Production Deployment:** Testing will be conducted in a controlled, simulated environment and will not involve live deployment on a real corporate production network due to legal, ethical, and privacy constraints [7].
- **Mobile and IoT AI Analysis:** The research is strictly restricted to desktop-based enterprise web traffic and API calls initiated from workstations.

6.3 Key Deliverables

The primary outputs of this research project include:

1. **Technical Research Proposal:** A comprehensive document detailing the project's foundation, objectives, and methodology.
2. **The Shadow AI Analytical Engine:** A modular Python-based prototype capable of parsing logs and detecting specific AI-agent signatures.
3. **WRSE Scoring Algorithm:** The core mathematical implementation of the risk assessment model developed for this project [8].
4. **Security Governance Dashboard:** A fully functional visualization interface for administrative monitoring and forensic log auditing [6].
5. **Final Research Thesis:** Detailed academic documentation (10,000+ words) covering the entire research lifecycle, evaluation of results, and future recommendations.

7 PROJECT TIMELINE AND MILESTONES

The proposed research is structured over a **12-week duration**, following an **Agile Prototype Development** methodology. Due to the technical complexity of the NLP and Risk Scoring modules, the timeline is prioritized to allow maximum time for iterative development and testing phases.

7.1 Implementation Roadmap (Phase-wise)

- **Phase 1: Foundation & Requirement Analysis (Weeks 1 - 2)**
 - Conducting an in-depth Literature Review on Shadow AI trends and enterprise risks.
 - Identifying gaps in existing cybersecurity governance frameworks for LLM usage.
 - **Milestone M1:** Research Problem Validation & Literature Synthesis.
- **Phase 2: Mathematical Framework Design (Weeks 3 - 4)**
 - Architecting the **Weighted Risk Scoring Engine (WRSE)** mathematical logic.
 - Defining and calibrating weighting coefficients (W_s , W_d , W_u) for the scoring model.
 - **Milestone M2:** Technical Approval of the Risk Scoring Logic.
- **Phase 3: Synthetic Data Engineering (Weeks 5 - 6)**
 - Generating high-fidelity synthetic network logs in JSON/CSV formats.
 - Developing the pre-processing pipeline for automated text normalization and tokenization.
 - **Milestone M3:** Testing Dataset Readiness and Verification.
- **Phase 4: Core Prototype Development (Weeks 7 - 9)**
 - Implementing the NLP Semantic Engine for deep content inspection.
 - Developing the Heuristic Behavioral Anomaly module to detect non-human agent signatures.

- Integrating the WRSE engine with analytical layers for real-time scoring.
- **Phase 5: System Integration & Stress Testing (Week 10)**
 - Designing and deploying the Streamlit-based Administrative Governance Dashboard.
 - Conducting end-to-end system testing, debugging, and logic validation.
 - **Milestone M4:** Functional Prototype Deployment and UI Verification.
- **Phase 6: Final Evaluation & Submission (Weeks 11 - 12)**
 - Performing result evaluation and forensic audit simulations.
 - Completing the Final Research Thesis and technical documentation for submission.
 - **Milestone M5:** Final Thesis Submission and Project Handover.

8 TOOLS AND RESOURCES

The development of the Shadow AI Risk Assessment framework requires a specialized technical stack to handle data simulation, semantic parsing, and interactive visualization. The selection of these tools is based on current industry trends in behavioral pattern recognition and automated risk scoring [5].

8.1 Software and Programming Environment

- **Python 3.10+ (The Core Engine):** The primary programming language used for developing the simulation engine and risk logic because of its extensive libraries for data analysis and security automation.
- **Pandas & NumPy (Data Processing):** These libraries are integrated for high-performance data manipulation, log normalization, and the execution of aggregate statistical features during the behavioral analysis phase [3].
- **Standard 're' Module & NLP Libraries (Content Inspection):** Python's regex module and optional Natural Language Processing (NLP) libraries are used for keyword-based content sensitivity detection and identifying proprietary corporate indicators (e.g., cloth textures, financial forecasts) within AI prompt payloads [4].

- **Streamlit Framework (Dashboarding):** This Python-based framework is employed to build the real-time governance dashboard, facilitating the visualization of risk scores and administrative alerts without extensive front-end coding [6].

8.2 Engineering and Simulation Tools

- **Visual Studio Code (VS Code):** This is the primary Integrated Development Environment (IDE) used for modular scripting, debugging, and iterative testing throughout the project lifecycle.
- **Git & Version Control:** Git will be utilized for maintaining an audit trail of the prototype's source code and configuration files, ensuring project integrity.
- **Synthetic Log Generators:** Custom-built Python scripts will be developed to generate AI API call logs in JSON format, capturing critical metadata such as timestamps, user identifiers, destination domains, and simplified prompt content [9].

8.3 Hardware and Data Infrastructure

- **Hardware Specifications:** A standard development workstation with a multi-core processor and sufficient RAM (minimum 8GB) is required to ensure low-latency processing of the dual-pronged inspection layers.
- **Synthetic Dataset Management:** All evaluations are performed on simulated AI traffic data generated by the project's proprietary scripts, which avoids the privacy constraints and ethical issues of using real-world organizational datasets [7].
- **Departmental Modeling:** The simulation will specifically model diverse departments, such as finance and design, with realistic frequencies and "burst" behaviors to provide a robust ground truth for evaluation.

9 CONCLUSION

The rapid integration of Artificial Intelligence (AI) into corporate environments has introduced a significant **Visibility and Governance Gap** that traditional security perimeters are currently unable to address [1]. Existing monitoring tools, such as standard firewalls and IDS, lack the semantic and behavioral depth required to quantify the risks associated with unmanaged AI agent interactions, particularly when traffic is routed through encrypted channels [9]. This research project addresses this critical vulnerability by proposing a prototype framework that successfully integrates behavioral pattern recognition with NLP-driven content inspection [2].

By implementing a **Weighted Risk Scoring Engine (WRSE)**, the framework effectively translates complex network telemetry including destination trust, prompt sensitivity, and user access levels into a standardized, actionable risk score [8]. The development of a Streamlit-based dashboard further demonstrates how these quantitative scores can be visualized to support real-time administrative monitoring and incident response [6].

Ultimately, this project bridges the gap between high-level governance policies and practical, network-level enforcement [5]. The successful deployment of this prototype on a high-fidelity synthetic dataset will provide a foundational model for automated AI risk management, ensuring that organizations can leverage the productivity gains of Generative AI without compromising their proprietary data integrity or security posture [11].

10 REFERENCES

- [1] Gartner, "Global cybersecurity trends 2026: The rise of shadow AI," Gartner Research, Stamford, CT, USA, 2026.
- [2] Palo Alto Networks, "Unit 42: Securing autonomous AI identities," Unit 42 Threat Intel Rep., Santa Clara, CA, USA, 2026.
- [3] J. Smith, "Behavioral pattern recognition in encrypted traffic," *IEEE Commun. Mag.*, vol. 63, no. 2, pp. 45-52, Feb. 2025.
- [4] R. Kumar, "Data leakage prevention for large language models," *Cyber J.*, vol. 18, no. 4, pp. 101-110, 2025.
- [5] A. White, "Governance frameworks for generative AI," *IT Prof.*, vol. 28, no. 1, pp. 30-38, Jan.-Feb. 2026.
- [6] S. Perera, "Automated risk scoring in corporate networks," *Security Weekly*, vol. 12, no. 3, pp. 20-27, 2026.
- [7] M. Davis, "The impact of shadow IT on modern enterprises," *Int. J. Comput. Syst.*, vol. 19, no. 1, pp. 11-19, 2024.
- [8] T. Anderson, "Weighted algorithms for risk mitigation," *Softw. Eng. J.*, vol. 32, no. 5, pp. 77-85, 2025.
- [9] K. Wilson, "Deep packet inspection challenges in 2026," *Network World*, vol. 40, no. 6, pp. 14-21, 2026.
- [10] "Shadow AI, cybersecurity, and emerging threats: Davos 2025 explores the risks," EDRM, Feb. 5, 2025.
- [11] "Shadow AI: Governance, risk, and organisational resilience," in Proc. 2025 Int. Conf. Cybersecurity and AI Governance, Aug. 2025, pp. 120-127.